FICHE 14 - GÉRER LA SOUS-TRAITANCE

Encadrer la sécurité des données avec les sous-traitants.

Les traitements de données réalisés par un sous-traitant[59] pour le compte du responsable de traitement doivent bénéficier de garanties suffisantes, notamment en matière de sécurité. Le responsable de traitement doit avoir connaissance du détail des mesures de sécurité mises en œuvre par ses sous-traitants pour pouvoir démontrer sa conformité[60].

Les précautions élémentaires

- **Faire appel uniquement à des sous-traitants présentant des garanties suffisantes** (notamment en termes de connaissances spécialisées, de fiabilité et de ressources).
- **Prévoir un contrat avec les sous-traitants**[61], qui définit notamment l'objet, la durée, la finalité du traitement ainsi que les obligations des parties, notamment en termes de sécurité. S'assurer qu'il contient en particulier des dispositions fixant :
  - la répartition des responsabilités et des obligations en matière de **confidentialité des données personnelles** confiées ;
  - des **contraintes minimales en matière d'authentification** des utilisateurs ;
  - **les conditions de restitution et de destruction des données** en fin du contrat ;
  - **les règles de gestion et de notification des incidents**. Celles-ci devraient comprendre une information du responsable de traitement en cas de découverte de faille de sécurité ou d'incident de sécurité et cela dans les plus brefs délais lorsqu'il s'agit d'une violation de données personnelles[62] ;
  - l'assistance que doit fournir le sous-traitant pour garantir le respect des obligations de sécurité[63] ;
  - la revue régulière des mesures de sécurité et, le cas échéant, les conditions de leur révision.
- **Prévoir les moyens permettant de vérifier l'effectivité des garanties offertes par le sous-traitant** en matière de protection des données (ex. : audits de sécurité, visite des installations). Ces garanties incluent notamment :
  - le chiffrement des données selon leur sensibilité ou, à défaut, l'existence de procédures garantissant que la société de prestation n'a pas accès aux données qui lui sont confiées si cela n'est pas nécessaire à l'exécution de son contrat ;
  - le chiffrement des transmissions de données (ex. : connexion de type HTTPS, mise en place de VPN) ;
  - des garanties en matière de protection du réseau, de traçabilité, de gestion des habilitations, d'authentification, de pratiques d'administration, d'audits, etc.

---

59 Entendu au sens du RGPD.

60 Articles 5.2 et 24.1 du RGPD.

61 La Commission européenne a publié des clauses contractuelles types sur lesquelles ce contrat peut reposer (voir « Clauses contractuelles types entre responsable de traitement et sous-traitant », cnil.fr).

62 Un incident de sécurité est caractérisé de « violation de données à caractère personnel » lorsqu'il touche à des données personnelles.

63 Se référer à l'article 32 du RGPD et au §41 des lignes directrices 07/2020 adoptées par le Comité européen à la protection des données (CEPD).